

L2 - 11.2. CTI for Alert Triage

Task 1 - Introduction

This room details how Cyber Threat Intelligence (CTI) streamlines alert triage, supports mature security operations, and helps analysts navigate common intel pitfalls and conflicting sources.

Task 2 - CTI vs Lookup Tools

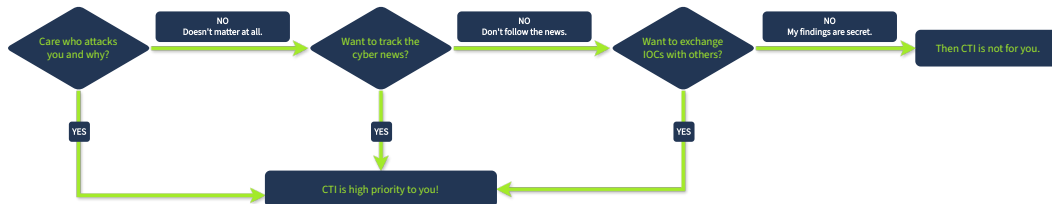
Threat Intelligence vs Lookup Tools: While **lookup tools** (like VirusTotal or AbuseIPDB) simply evaluate if a single indicator is malicious, **Cyber Threat Intelligence (CTI)** provides context—linking an indicator to specific threat actors, campaigns, related infrastructure, and your organization's history with it. L1 is about lookups and making a decision whether the activity is malicious or not, but L2 is about contextualizing the threat.

Question you ask	Lookup result	CTI answer
Is this an attack indicator?	Yes, Trojan:JS/Agent	Yes, and explains why
What threat actor is it tied to?	N/A	Mini Shai Hulud campaign, TeamPCP threat group
What related indicators exist?	N/A	Domains, IPs, hashes, and MITRE techniques to hunt for
Has my organization seen this before?	N/A	Yes, already encountered TeamPCP activity before

Purpose of CTI: Advanced Cyber Threat Intelligence (CTI) provides attack context—such as adversary motives, methods, and indicators—to help small teams speed up investigations and focus threat hunting. For enterprise organizations and law enforcement, CTI expands beyond context to support strategic defense, adversary attribution, active threat hunting, and infrastructure takedowns.

- **Attribution:** Link activity to specific threat actors, which is essential for legal action and coordinated response

- **Proactive defense:** Prepare for attacks before they happen by tracking adversary tooling and behavior
- **Information sharing:** Share indicators externally so other communities can defend against the same threats
- **Incident response:** Accelerate containment and remediation by correlating against known adversary TTPs



MISP and OpenCTI

There are two popular open-source CTI platforms that serve different purposes: [MISP](#)([opens in new tab](#)), which focuses on sharing and tracking individual attack indicators (IOCs), and [OpenCTI](#)([opens in new tab](#)), which goes further by connecting those indicators into full profiles of known threat actors, their tools, TTPs, and campaigns. You will practice with both in the next rooms; but for now, just note the names.

Answer the questions below

Reputation lookups can support you with a verdict. What does CTI add to make sense of the attack?

Context

What is the term for mapping activity to known threat actors or APT groups?

Attribution

Task 3 - CTI for Alert Triage

SIEM Alert Scenario: You're working the morning queue as an L2 analyst. L1 received a medium-severity alert and flagged it for your review. Let's see how CTI can help, starting with an input: a SIEM alert. Looking at the alert below,

node.exe appears to be an infostealer, but you can't clearly classify the alert yet, and don't know which Node.js script caused the behavior.

[SIEM Alert]

Rule Name : Credential access attempt by untrusted process
Timestamp : 2026-06-01 08:14:32 UTC

[Triggering Event]

event_type : file_access
process_name : node.exe
process_id : 4821
process_sig : Signed (Node.js)
user : CORP\j.okafor
host : WKSTN-047
accessed_files : ~/.ssh/id_rsa, ~/.aws/credentials, .env, .npmrc

Step 1: Alert Triage: As part of a regular L2 triage, you'd build a timeline of events to understand what node.exe did, what caused it to launch, and whether it is expected for a Node.js process to access development credentials. From the process tree below, you'd assume the activity started after a user opened VS Code, installed a Node.js project from there (**npm install**), which caused the Node.js process to launch a suspicious **index.js** file - all matching a supply chain pattern.

```
explorer.exe      [08:06:55]
├─ code.exe      [08:13:34]
│   └─ npm install [08:14:10]
│       └─ node index.js [08:14:32]
```

Basic Reputation Checks: You would then investigate the **index.js** script, either manually or in a sandbox. The script will tell you exactly what it does and prove that it is indeed an infostealer. You'd also get valuable indicators, such as its hash, notable strings, hardcoded tokens and URLs, and other IOCs you'd need for the next step, CTI analysis.

[Static Analysis]

```
Analyzed File      : index.js
VT Detections      : 7/61 (InfoStealer:JS)
Notable String     : python-requests/2.31.0 (User-Agent)
Notable String     : https://api.github.com (URL Address)
Notable String     : AWS_SECRET_ACCESS_KEY (Sensitive)
SHA256             : d8d170af3de17bb9b217c52aaaffdf9395f35ef015
                   : a57ef676e406c121e5e223
```

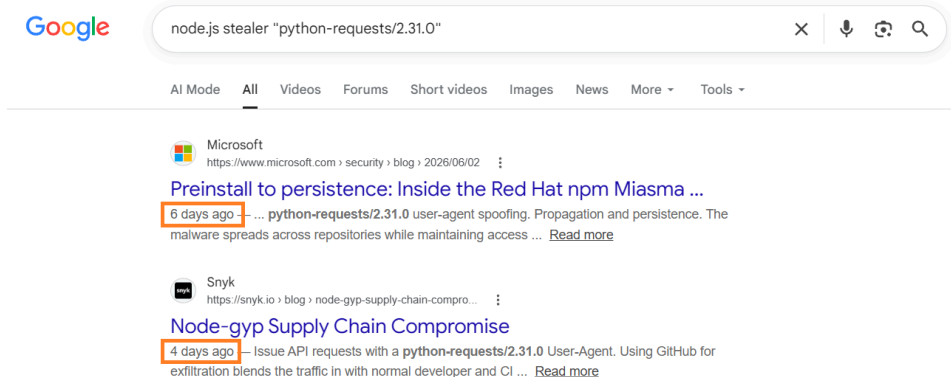
[Dynamic Analysis]

```
High-risk          : Cloud and Kubernetes secrets enumeration
High-risk          : Enumeration of common secrets' location
Informational       : Suspicious GitHub API activity
```

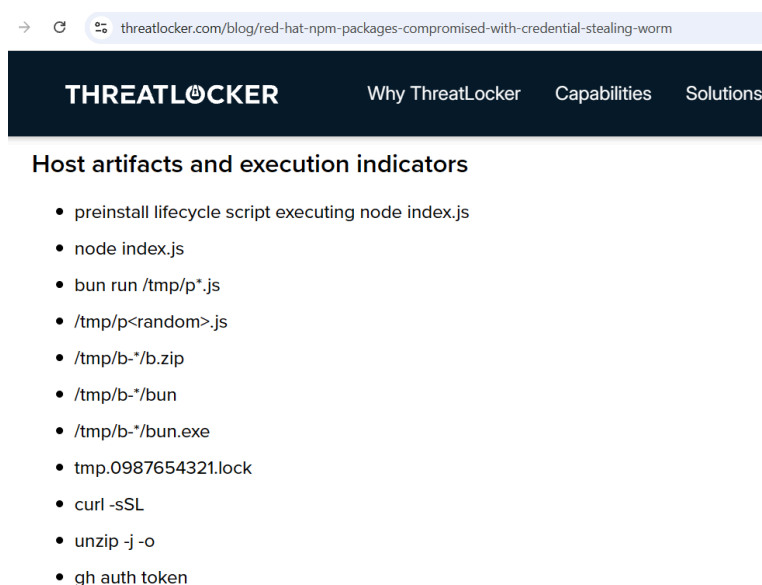
Step 2: CTI Analysis: Even though you are sure the activity is malicious, the telemetry doesn't tell you how the attack started or how to respond to it properly. Your first instinct might be to access the workstation, collect forensic artifacts, and begin a deep triage to reconstruct the attack and identify how the supply chain attack started. But before that, try using CTI, where your steps would be:

1. Check if any indicators match events in your MISP instance (e.g., file hashes, IPs, or domains)
2. Check for OpenCTI reports matching the behavior (e.g., Node.js data stealer using GitHub API)
3. Google recent public reports by searching for keywords in quotes (e.g., **"python-requests/2.31.0"**)

Finding Public Reports: Small SOC teams that don't have a paid subscription to CTI services like Recorded Future and aren't eligible for private CTI feeds, like those from NATO MISP, can jump straight to step #3. Check out the screenshot below. A simple Google search [revealed\(opens in new tab\)](#) multiple recent threat reports, all matching the behavior you saw:



From there, you'd see that the activity matches a Miasma supply chain campaign and lists the exact NPM packages that have been compromised. These public reports will provide you with further IOCs you might have missed, suggest remediation steps, and point you in the right direction in your investigation. Note that in bigger companies, you'd rely more on private MISP or OpenCTI data than public reports (actually, you are more likely to write a public report first), but the flow would be the same.



Public reports may explain the attack chain and provide you with further IOCs to hunt for ([ThreatLocker](#) (opens in new tab))

Answer the questions below

What anomalous user-agent did the Node.js malware use?

python-requests/2.31.0

Explore the public reports explaining the Miasma supply chain attack.
Repositories of which company were compromised? (e.g., Oracle)

Red Hat

Task 4 - Reliability of Threat Intel

Reliability of CTI Reports: You'd then correlate your data with the report, hunt for the reported indicators, and close the alert as a True Positive. For the next alert, it might be tempting to go straight to public reports and, if the activity looks similar, triage it exactly as the report says without digging into your own logs. Such an approach will eventually cause a missed threat, because:

- A report may list only half the indicators; the REST are unique to your case
- The initial access might match, but the next steps could differ completely
- It can fool you into thinking you face a different, unrelated attack campaign
- Reports can be misleading, especially on websites that just re-post intel

REST (representational state transfer) is a software architectural style that was created to guide the design and development of the architecture for the World Wide Web. REST defines a set of constraints for how the architecture of a distributed, Internet-scale hypermedia system, such as the Web, should behave.

TIP: *Carefully correlate CTI reports and your SIEM data. Verify each report statement against evidence in your own logs.*

Reliability of Indicators: Another important thing to remember is that the mentioned indicator doesn't necessarily indicate a malicious one. Adversaries may use legitimate tools and online services to achieve malicious goals, and CTI reports often include that context alongside real malware indicators. Beginners often struggle to distinguish these two, and I have seen several cases where analysts made big mistakes after misinterpreting CTI. Here are a few examples of these mistakes:

Example #1: A CTI report stated that the adversary used <https://api.myip.com/> (opens in new tab) (a legitimate service) to query the

victim's IP. The analyst found that over 20 laptops used that service in the past, and mistakenly declared them all infected.

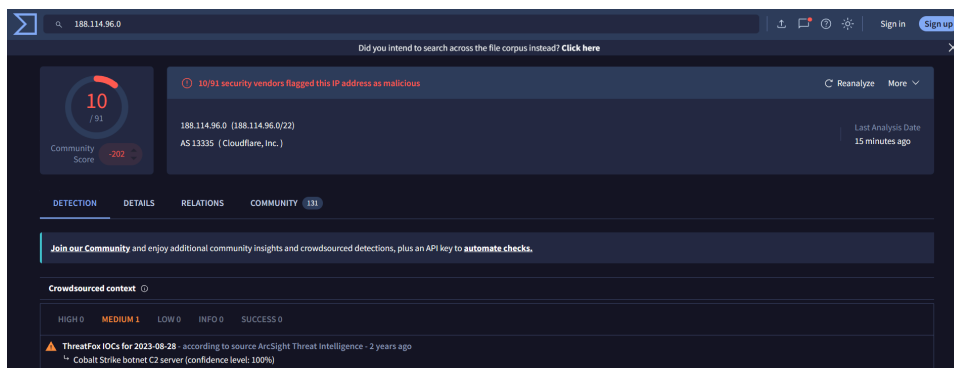


The screenshot shows the VirusTotal interface for the domain `api.myip.com`. It displays a table of files that have referred to this domain. The table has four columns: Scanned, Detections, Type, and Name. The data is as follows:

Scanned	Detections	Type	Name
2026-06-08	4 / 66	Android	USA-VPN-v1.135-MOD-OTR-(Getmodsapk.com).apk
2026-06-08	13 / 59	Python byte-compiled	4ce39b77030cd28b5a7d5c96ef0df583a63c4c399f9a42fb5dbdfce66d92fe51
2026-06-08	1 / 67	Android	karing_1.2.20.2302_android_arm.apk
2026-06-08	20 / 70	Win32 EXE	MaxTwitterPro.exe
2026-06-08	3 / 47	Android	Fotor_Mod_v7.8.3.0_Modfyp.com.apk.zip
2026-06-08	2 / 60	Android	2ef41b9f31a639fee355fa008dc59155010fd89078d39c75d5f980dc1be1e17a.file
2026-06-08	11 / 70	Win32 DLL	tool.dll
2026-06-07	24 / 71	Win32 EXE	yt728.exe
2026-06-07	22 / 71	Win32 EXE	5ax1ot9f.exe
2026-06-08	2 / 59	Android	Fotor 7.5.0.2.apk

Both good and bad files contact api.myip.com. Its presence in logs may hint at an attack but doesn't prove one on its own.

Example #2: Another report mentioned the adversary using Cloudflare CDN for Command & Control communication. The analyst checked the Cloudflare IP on VirusTotal, saw the "red" report, and added the IP to the blocklist. Cloudflare addresses are shared across thousands of websites, so the action resulted in many False Positives.



The screenshot shows the VirusTotal report for the IP address `188.114.96.0`. The report includes a community score of 10/91, a status of "10/91 security vendors flagged this IP address as malicious", and a last analysis date of 15 minutes ago. The report also shows a "Crowdsourced context" section with a "MEDIUM 1" rating and a "ThreatFox IOCs for 2023-08-28" entry.

VirusTotal marks Cloudflare's IP address as clearly malicious. But an experienced analyst will know the VT score does not apply to CDN IPs.

IOC Validity Time: Lastly, remember that even the most reliable reports from your colleagues won't be actionable after some time. For example, an AWS or DigitalOcean IP address reported as a C2 server will change ownership in a few days or weeks after the attack and then point to a legitimate website. MISP events are generally shared with a suggested validity time (also known as decay time

or TTL). Still, you can also define your own validity rules for auto-blocking or alerting on indicators. For example:

- **File hashes:** Permanent blocking and alerting
- **Domain names:** 1 year for active blocking, then permanent alerting
- **IP addresses:** 14 days for active blocking, then alerting for 30-90 days

***TIP:** As in the military, intelligence becomes outdated over time. Account for it in your SOC operations*

Answer the questions below

According to the validity rules, what blocking applies to file hashes?

Permanent

You should never accept a report's claim without validation. Where should you find the evidence that confirms the claim?

Your logs

Task 5 - Weighing and Making the Call

Weighing the Intel: Threat intelligence can be contradictory, and it takes skill to determine which sources are reliable and accurate, and which to trust first. MISP events can contain the appropriate tags to express intel origin and confidence, but some principles apply consistently:

#	Principle	Description
1	Activity you see with your eyes outweighs everything	If you see a confirmed malicious activity in your SIEM, CTI should only supplement it with new indicators or attribute it to a campaign, not override the logs.
2	Internal intelligence outweighs external by default	A MISP event your own CTI team authored carries more weight than an anonymous OTX pulse or public blog post. You can also clarify that intel and make it more actionable.
3	Linked indicator outweighs an	An indicator linked to an active campaign and its kill chain is valuable intel. But a single reported

#	Principle	Description
	independent one	bad domain with no linked context is no better than a VirusTotal lookup.

Applying Weights: When working in a CTI team and investigating a campaign, you aggregate intel from multiple sources and decide how much uncertain information to include: create a broad MISP event that mixes solid and speculative findings, a narrow event limited to what you can prove, or a balance of the two with each attribute tagged at its own confidence. Whatever you produce, SOC teams will then weigh your report against the other intelligence they hold.

Summary: *As a SOC analyst, weigh CTI against what you can see yourself. As a CTI producer, be precise about your confidence level.*

Answer the questions below

| Does internal intelligence outweigh external intelligence? (Yea/Nay)

Yea

| When authoring an event, what should you be very clear and precise with?

Confidence Level

Task 6 - Challenge: The Standalone Alert

The Standalone Alert: Apply your CTI skills to investigate an alert and make an intel handoff note from it. You will start with a SIEM alert and use internal MISP and OpenCTI data to gather additional context. Open the static site by clicking the **View Static Site** button below and complete the two-part challenge to receive the flag.

Answer the questions below

| Boyko What is the flag retrieved after completing the challenge?

THM{cti_is_more_than_vt_lookup!}

CTI Challenge
Restart
Full Screen

Intel Analysis

Review the alert and the intel artifacts. Then answer the questions.

SIEM Alert

```

[SIEM Rule]
Rule ID      : R-1389
Rule Name    : Office application spawning executable
Severity     : High
Timestamp    : 2026-06-09 14:03:11 UTC
MITRE        : T1566.001 (Spearphishing Attachment)

[Triggering Event]
event_type   : process_creation
process_pid  : 9842
process_name : onboarding_form.exe
process_hash : 9c2e77...b14f30
parent_name  : wscript.exe
grandparent_name : winword.exe
user         : CORP\l.obi
host         : PC-EU-204

```

MISP Event

```

[MISP Event]
Title       : HR-themed phishing campaign - May 2026
TLP         : Amber
Threat      : High
Analysis    : Ongoing
Tags        : admiralty-scale:source-reliability="a"
             internal:source="EMEA CTI Team"
Galaxies    : malware:Cobalt Strike
             mitre-attack-pattern:T1566.001
             mitre-attack-pattern:T1059.005

[MISP Attributes]
Domain      : hr-portal-secure[.]com
Domain      : hr-onboarding-check[.]com
SHA256      : 23fb39...ac0176 (candidate_cv.docx)
SHA256      : 4b8a11...cc9f02 (resignation.docx)
SHA256      : 9c2e77...b14f30 (onboarding_form.exe)

Analyst note:
HR-focused phishing wave was observed across the region starting
end of May, 2026. Themed emails from compromised SMTP servers
deliver macro-enabled DOCX files that download Cobalt Strike C2
from the HR-themed domains, registered 2-5 days before use.

```

OpenCTI Campaign Report

```

[OpenCTI Report]
ID          : intrusion-set--49f8b1c0-3d7a-4e25-b96f-8alc5d2e0734
Name        : UNC-011 delivers Cobalt Strike via MS Office macros
Status      : Active
First observed : 2026-04-12
Last observed  : 2026-05-28

[Intrusion Set]
Attributed actor : Unknown (UNC-011)
Primary motive   : Financial gain
Victimology      : HR, finance, and recruitment roles

```

Question 1 of 5

Which MITRE ATT&CK sub-technique ID is used for the initial access stage of this campaign?

- ☐ T1218.005 (Mshta)
- ☒ T1566.001 (Spearphishing Attachment)
- ☐ T1566.002 (Spearphishing Link)
- ☐ T1059.001 (PowerShell)

✓ Correct

The SIEM rule is mapped to T1566.001, and MISP galaxies and the OpenCTI kill chain both list the Spearphishing Attachment.

Question 2 of 5

Looking at the MISP event, how many indicators (IOCs) are tied to the attack campaign?

- ☐ 2
- ☐ 3
- ☐ 4
- ☒ 5

✓ Correct

One IOC you saw in the SIEM alert (onboarding_form.exe), two DOCX attachments, and two C2 domains you can hunt for. Five indicators total.

Question 3 of 5

According to the OpenCTI report, when was this campaign first observed?

- ☐ August, 2024
- ☒ April, 2026
- ☐ May, 2026
- ☐ June, 2026

✓ Correct

The "First Observed" field is set to 2026-04-12. The May MISP report is a later instance of activity OpenCTI has tracked since April.

CTI Challenge

Restart

Full Screen

HR-focused phishing wave was observed across the region starting end of May, 2026. Themed emails from compromised SMTP servers deliver macro-enabled DOCX files that download Cobalt Strike C2 from the HR-themed domains, registered 2-5 days before use.

▼ OpenCTI Campaign Report

[OpenCTI Report]

ID : intrusion-set--49f8b1c0-3d7a-4e25-b96f-8a1c5d2e0736

Name : UNC-011 delivers Cobalt Strike via MS Office macros

Status : Active

First observed : 2026-04-12

Last observed : 2026-05-28

[Intrusion Set]

Attributed actor : Unknown (UNC-011)

Primary motive : Financial gain

Victimology : HR, finance, and recruitment roles

[Knowledge]

Used Malware : Cobalt Strike

Exploited CVE : CVE-2026-21509

Exploited CVE : CVE-2025-21298

[Kill Chain]

1. Spearphishing attachment (T1566.001)

2. User enables macro; macro spawns wscript (T1059.005)

3. Wscript drops second-stage C2 beacon (T1105)

4. Beacon persists via scheduled tasks (T1053.005)

5. Hands-on-keyboard activity and pivoting (T1083)

[Suggested Hunts]

- Thematically-named MS Office files in Downloads / Temp

- PowerShell or wscript spawned by MS Office applications

- Creation of suspicious HKCU Run key entries

- Outbound traffic to the themed DNS domains

▼ EDR Telemetry

[Network Telemetry]

Analyzed Process : onboarding_form.exe (9042)

DNS Resolution : hr-portal-secure[.]com

DNS Resolution : trust-service-eu[.]com

[Filesystem Telemetry]

Analyzed Process : onboarding_form.exe (9042)

Created File : C:\Windows\System32\Tasks\WinUpd.xml

Question 3 of 5

According to the OpenCTI report, when was this campaign first observed?

● August, 2024

● April, 2026

● May, 2026

● June, 2026

✓ Correct

The "First Observed" field is set to 2026-04-12. The May MISP report is a later instance of activity OpenCTI has tracked since April.

Question 4 of 5

What is the strongest piece of intel supporting a malicious classification for this alert?

● The domain names were registered 2-5 days before the attack

● The activity happened on the HR workstation, PC-EU-204

● The indicators match a trusted MISP event and are linked to an active campaign

● The grandparent process was winword.exe (Microsoft Word)

✓ Correct

Internal CTI team intel with an active campaign match and a documented TTP chain in OpenCTI outweighs any single behavioral signal.

Question 5 of 5

What indicator observed in SIEM/EDR has NOT been previously mentioned in MISP or OpenCTI?

● trust-service-eu[.]com (DNS)

● onboarding_form.exe (File)

● hr-onboarding-check[.]com (DNS)

● winword.exe (File)

✓ Correct

Only trust-service-eu[.]com is a new indicator. Atomic IOCs are short-lived, so fresh domains can appear with every attack wave.

Continue to Part 2

All answers correct

L2 - 11.2. CTI for Alert Triage

11

CTI Challenge

PART 2 OF 2

Complete the Intel Handoff Note

Drag the correct Intel cards into each handoff note field. The Intel sources you reviewed in Part 1 remain available on the left for reference. Some cards belong to a different investigation or are not intel at all; only Intel relevant to this alert should be included.

END OF MAY, 2026. THEMED EMAILS FROM COMPROMISED ONIR servers deliver macro-enabled DOCX files that download Cobalt Strike C2 from the HR-themed domains, registered 2-5 days before use.

▼ OpenCTI Campaign Report

[OpenCTI Report]

ID : intrusion-set--49f8b1c0-3d7a-4e25-b96f-8a1c5d2e0734
Name : UNC-011 delivers Cobalt Strike via MS Office macros
Status : Active
First observed : 2026-04-12
Last observed : 2026-05-28

[Intrusion Set]

Attributed actor : Unknown (UNC-011)
Primary motive : Financial gain
Victimology : HR, finance, and recruitment roles

[Knowledge]

Used Malware : Cobalt Strike
Exploited CVE : CVE-2026-21509
Exploited CVE : CVE-2025-21298

[Kill Chain]

1. Spearphishing attachment (T1566.001)
2. User enables macro; macro spawns wscript (T1059.005)
3. Wscript drops second-stage C2 beacon (T1185)
4. Beacon persists via scheduled tasks (T1053.005)
5. Hands-on-keyboard activity and pivoting (T1003)

[Suggested Hunts]

- Thematically-named MS Office files in Downloads / Temp
- PowerShell or wscript spawned by MS Office applications
- Creation of suspicious HKCU Run key entries
- Outbound traffic to the themed DNS domains

Intel Handoff Note

Date: June 09, 2026
Title: New wave of HR-themed phishing
Classification: **Confirmed Malicious**
Confidence: **High Confidence**

IOCs

Indicators of compromise observed in this investigation

Domain name: trust-service-eu[.]com

File and hash: onboarding_form.exe

Domain name: hr-portal-secure[.]com

Campaign Context

The campaign and MITRE techniques this intel maps to

Observed TTP: T1566.001 (Spearphishing Attachment)

Link to the MISP event (HR-themed phishing campaign)

Link to the OpenCTI event (intrusion-set--49f8b1c0...)

Intel Gaps

What you do not yet know

Hands-on-keyboard activity not yet identified; PC-EU-204 is pending DFIR

Phishing email IOCs, such as subject or sender, aren't yet identified

Submit Handoff Note

Ready to submit

Task 7 - Conclusion

The scenario in this room gave you an overview of what a useful MISP event looks like; the next room shows you how to get there yourself.